

UI/UX Remediation Rollout and Rollback Runbook

Progressive cohorts, production guardrails, incident response and rollback

ENTERPRISE REMEDIATION REPORT

Published 2026-08-06

Evidence-led | contract-governed | accessibility-aware | rollout-ready

Truthful workflows. Explicit controls. Verifiable enterprise evidence.

Program: STQ-UIUX-REM-2026-08-06 **Owner:** Release Director **Applies to:** contract, route, capability, visual-system, module-normalization, onboarding, and certification changes defined by this roadmap.

1. Safety principles

- 1 Financial truth, tenant isolation, server authorization, audit evidence, and durable business records are never rolled back by deleting or rewriting data.
- 2 UI rollback restores presentation/orchestration paths only. Schema and data migrations require forward-compatible expansion/contraction and a separately approved data runbook.
- 3 A capability rollback may return a policy cohort from `enforce` to `observe`; it must not bypass existing server permission checks.
- 4 A failed read renders `partial`, `stale`, or `unavailable`; rollback must never restore null-to-empty or false-zero behavior.
- 5 An action without a trustworthy result is disabled with an explicit reason; simulated success is never a fallback.
- 6 Each rollout unit is independently observable and reversible. No multi-module big-bang activation.
- 7 Flags have owner, creation date, expiry, default, cohort rules, audit log, and removal work item. Permanent flag debt is a failed rollout.

2. Preconditions

The Release Director must verify before any production exposure:

- 1 the relevant phase and module gate is signed in `06_PHASE_GATES_AND_RELEASE_CRITERIA.md`;
- 1 all mapped P0 findings are closed for the rollout scope;
- 1 the certification manifest contains the affected route/action/role/package/state combinations;
- 1 automated evidence is green and fresh; human validation is signed where required;
- 1 a production build, migration preflight, secrets preflight, and current policy gates pass;
- 1 dashboards and alerts distinguish old/new code paths and rollout cohorts;
- 1 support has the change brief, denial/error-state decision tree, known risks, and escalation contacts;
- 1 the rollback owner has rehearsed the exact rollback in a production-like environment;
- 1 data compatibility is bi-directional for the duration of the rollback window; and
- 1 no unrelated incident is degrading the affected domain.

3. Standard cohort sequence

R0 — dark/shadow	Internal telemetry only; old experience remains authoritative	2 business cycles or 24 h	Decision/read-model parity within approved tolerance; no cross-tenant or capability mismatch	Any tenant leak, incorrect financial truth, policy mismatch, or unbounded error
R1 — staff	Stoquify staff and seeded demonstration organizations	1 business day	All Tier-0/1 scenarios green; support rehearsal complete	P0/P1 control failure; >2× baseline error rate; unrecoverable task
R2 — design partners	1–3 consenting low-risk organizations, one country/currency at a time	2–3 business days	Domain signoff; no material support/adoption regression; telemetry stable	Reconciliation mismatch; false completion; serious accessibility regression; rollback RTO breach
R3 — 5%	Randomized eligible organizations, excluding high-risk close/payroll windows	2 business days	Error, latency, completion, denial and support metrics within budget	Guardrail breach for two windows or any single critical event
R4 — 25%	Eligible organizations by package/country	3 business days	No unexplained cohort divergence; evidence remains fresh	Same as R3; material country/locale/currency defect
R5 — 50%	Broad eligible cohort	3 business days	SRE, product, domain, support approvals	Same as R3/R4
R6 — 100%	All eligible organizations	7-day heightened monitoring	No open blocker; flag-removal ticket scheduled	Critical event triggers rollback to last safe cohort
R7 — cleanup	Remove compatibility path/flag after rollback window	After 14–30 days by risk	Independent assurance confirms stable metrics and retained evidence	Any unresolved dependency on legacy path pauses removal

Do not promote payroll during an active payroll run, close/reconciliation during a period-close window, or POS offline/replay changes during a peak trading window unless the domain owner explicitly accepts the operational risk.

4. Rollout units and rollback procedures

4.1 CT-01 inventory summary/read model

Flag: organization-level `inventory_summary_v2`; shadow comparison before display activation. **Observe:** old/new totals, counts, filters, location scope, `asOf`, currency, `sourceStatus`, partial rate, query latency. **Promote when:** deterministic reconciliation is exact; page-size invariant; no tenant/location mismatch; P95 within approved budget. **Rollback:** switch display to the last trusted read path, retain shadow logging, and render a visible degraded/unavailable state if the trusted path cannot satisfy provenance. Do not change inventory transactions or recompute stored balances during UI rollback. **Critical trigger:** any KPI materially disagrees with reconciled source truth or a failed read appears as zero.

4.2 CT-03 DisplayContext and money presentation

Flag: per module/surface, never global-first. **Observe:** context resolution failures, fallback attempts, currency/locale/time-zone mismatch, formatting exceptions, export/notification parity. **Promote when:** EN/FR × XAF/XOF/EUR/USD fixtures and domain samples pass. **Rollback:** use the previous surface formatter only if it receives an explicit resolved context; otherwise show configuration/unavailable. Never silently default production money to USD. **Critical trigger:** wrong currency symbol/code, separator causing value ambiguity, or screen/export disagreement.

4.3 CT-04 capability and module entitlement

Stages: report → observe → enforce for one low-risk module and fixture cohort → staff → design partner → organization cohorts. **Observe:** UI/server decision mismatch, entitled denial, non-entitled allow, route/action/source, policy version, provider shadow state, organization/location scope. **Promote when:** all protected surfaces are registered; mismatch is zero for required fixtures; security and commercial owners sign. **Rollback:** return the affected policy/module/cohort to **observe**; preserve server permission checks, provider/billing truth, decision logs, and explicit UI state. If exposure is possible, hide/disable the surface and contain before observe-mode fallback. **Critical trigger:** unauthorized access, cross-tenant access, purchased feature denied at scale, or billing/provider drift with unsafe exposure.

4.4 CT-05 routes and aliases

Stages: add canonical metadata → introduce locale/query-preserving redirect → update internal links/docs/analytics → observe alias traffic → retire after threshold. **Observe:** redirect failures/loops, 404s, alias traffic, bookmark/support referrals, analytics continuity. **Rollback:** restore the alias redirect and canonical analytics mapping. Never restore a second active implementation for the same intent. **Trigger:** redirect loop, lost locale/query state, material 404 increase, or broken authorization boundary.

4.5 CT-06 actions and exports

Stages: inventory controls → disable false controls → activate real handler for internal cohort → validate artifacts → broader rollout. **Observe:** action start/completion/failure, correlation ID, idempotency key, artifact creation/download, row count, filters, expiry, retry. **Rollback:** disable the control with reason and support path; allow retrieval of already-created artifacts if safe. Never issue a success toast without durable success evidence. **Critical trigger:** false completion, duplicate mutation, wrong-scope export, corrupt artifact, or privacy leak.

4.6 CT-07 accessibility primitives and public/auth funnel

Flag: page/layout cohort while shared field semantics remain compatible. **Observe:** auth error/abandonment, focus exceptions, field validation, route errors, support contacts; automated accessibility in CI. **Promote when:** axe, keyboard, reflow, screen-reader and localization validation pass. **Rollback:** restore prior visual composition only if remediated semantic fields, error associations, focus behavior, autocomplete, and announcements remain. **Critical trigger:** keyboard trap, inability to authenticate, lost error announcement, critical/serious regression, or conversion collapse beyond agreed guardrail.

4.7 CT-08 tokens/themes and module visual migrations

Stages: token aliases → shared primitives → one low-risk surface → top-20 → module waves. **Observe:** screenshot diffs, contrast, theme preference mismatch, hydration/layout shift, CSS size and overrides. **Rollback:** revert the affected module to versioned compatibility tokens; retain the semantic API and remove the faulty recipe. Do not reintroduce an unowned global theme island. **Trigger:** unreadable content, contrast blocker, theme preference ignored, or widespread layout break.

4.8 CT-09 onboarding

Flag: new organizations only; existing in-progress users remain on a versioned state schema unless migrated. **Observe:** signup completion, first-input visibility, resume success, time to first value, drop-off by step/device/locale, support contacts. **Rollback:** route new signups to prior flow while preserving identity/account records and versioned onboarding progress; migrate only with tested forward/backward adapters. **Trigger:** account creation loss, resume corruption, compliance omission, or significant completion regression.

4.9 C-module normalization and C-07 decomposition

Unit: one bounded workflow/surface, not an entire domain at once. **Observe:** route-state distribution, errors, latency, task completion, action outcomes, denial/mismatch, bundle/render metrics and domain-control reconciliation.

Rollback: surface flag or server orchestration switch to the characterized path; data contracts remain backward

compatible. **Trigger:** control/tie-out failure, regression outside characterized behavior, performance budget breach, or support cannot recover the workflow.

5. Incident decision table

Cross-tenant data/capability leak	SEV-0	Disable surface/action; contain; security incident process; rollback cohort	Security Incident Commander	Decision logs, request IDs, actor/tenant scope, flag/config, traces
Incorrect financial/control truth	SEV-0/1	Stop affected workflow; label data unavailable; rollback read/presentation cohort	Accounting Controls Lead + Incident Commander	Source/read-model comparison, as-of, filters, currency, screenshots
False success or duplicate mutation	SEV-1	Disable action; stop retries; inspect idempotency/artifacts	Domain Lead + App Platform	Correlation/idempotency IDs, artifact/job records, audit trail
Critical/serious accessibility regression	SEV-1	Pause public/auth or affected route cohort; provide accessible fallback	Accessibility Lead + Release Director	Axe/AT output, browser/viewport, recording, commit
Entitled-user denial surge	SEV-1	Return policy cohort to observe if safe; maintain server auth	Entitlements Lead	Decision versions, provider state, role/package fixture
Error/latency guardrail breach	SEV-2 unless control path	Pause promotion; profile; rollback after two breached windows	SRE Lead	Metrics, traces, deploy/flag timeline
Cosmetic diff outside critical workflow	SEV-3	Record and fix in normal cadence	Product/Design owner	Screenshot metadata and issue

6. Rollback execution checklist

- 1 Declare incident and freeze promotions.
- 2 Identify exact contract, route, module, cohort, commit, flag version, tenant/package/country, and start time.
- 3 Preserve logs, traces, screenshots, artifact IDs, capability decisions, and configuration before mutation.
- 4 Select the narrowest rollback above; verify server authorization and data invariants remain intact.
- 5 Apply through audited flag/config/deploy mechanisms with two-person approval for financial, security, payroll, close, or entitlement changes.
- 6 Run the Tier-0 smoke plus the failed scenario on the rollback state.
- 7 Confirm error/control metrics return to baseline and no queued job/replay remains unsafe.
- 8 Notify support and affected stakeholders with impact, workaround, data status, and next update.
- 9 Keep the rollout paused until root cause, corrective test, refreshed evidence, and re-approval exist.
- 10 Record the event in 08_RISK_ASSUMPTION_DECISION_LOG.md and the final readiness pack.

7. Rollback RTO targets

SEV-0 security/tenant	5 min	15 min	Contain; no destructive repair without incident approval
Financial truth/action	10 min	30 min	Preserve records; reconcile forward
Capability/entitlement	10 min	30 min	Observe-mode or safe hide; preserve authorization
Public/auth accessibility/function	15 min	45 min	Preserve accounts/session integrity
Module visual/workflow	30 min	60 min	Revert presentation/orchestration only
Alias/content/cosmetic	60 min	1 business day	No business-data effect expected

Targets are hypotheses until D-04 drills demonstrate them. Actual measured RTOs replace these values in the final readiness report.

8. Post-rollout cleanup

- 1 remove expired flags and compatibility aliases only after their observation window;
- 1 retain certification and rollout evidence according to the audit retention policy;
- 1 update route/capability/contract versions and support documentation;
- 1 close incident actions only after regression tests are merged and exercised;
- 1 compare realized adoption, errors, control exceptions, accessibility, and support load with the baseline; and
- 1 send unresolved risk or decision changes back through Gate 0 governance rather than normalizing exceptions.